



Directory > ... >

Using a zero trust framework to secure
SaaS applications

Copy page



Using a zero trust framework to secure SaaS applications

Last reviewed: 12 months ago

Introduction

SaaS applications have become crucial in today's business landscape, particularly with the rise of hybrid workforces. As organizations adopt flexible working models, the ability of SaaS apps to provide seamless, global access is essential for maintaining productivity and fostering collaboration across distributed teams.

SaaS applications significantly reduce the burden on IT teams by eliminating the need to manage the underlying infrastructure. By entrusting these responsibilities to the SaaS provider, organizations no longer need to worry about hardware and software lifecycle management or scalability challenges. Furthermore, the subscription-based model of SaaS applications lowers adoption barriers by minimizing upfront costs and ultimately offer a lower Total Cost of Ownership (TCO) compared to legacy applications.

Along with these advantages, SaaS applications introduce new challenges and security risks. Their Internet accessibility requires greater focus on the security of users and devices to prevent unauthorized access and data leaks. User provisioning (onboarding/offboarding), appropriate access controls and control/visibility into device security is essential to ensure only authorized users on trusted devices access company applications. Moreover, IT teams must monitor SaaS applications for misconfiguration and gain visibility into risky user activity. Employees might

publicly share files that contain sensitive information or integrate managed SaaS applications with unauthorized third-party apps, all without the IT team's knowledge.

The ease with which users can sign up for new SaaS services, particularly free and popular ones, often leaves IT teams unaware of all the applications employees use -- a trend known as [shadow IT ↗](#). These unmanaged SaaS applications can be misused by employees, either intentionally or accidentally, potentially leading to data leaks due to the upload of sensitive data into applications that are not under the control of the IT team.

Trying to use a [traditional castle-and-moat security model ↗](#) is unsuitable for SaaS applications, as the services and their data are no longer confined to on-premises data centers within an enterprise network. This outdated approach forces a trade-off between security and performance:

- One strategy organizations adopt to enhance security involves shielding SaaS applications from the broader Internet by implementing IP allow lists and routing traffic through the organization's data center where traffic can be inspected and filtered according to security policy. However, this method negatively impacts the user experience, leading to increased latency and reduced bandwidth when routing all traffic through a single data center.
- Conversely, if user traffic is sent directly to the Internet, bypassing a local VPN client by using split tunneling, security and visibility are compromised as enterprise network controls are bypassed (and IP allow lists are no longer feasible).

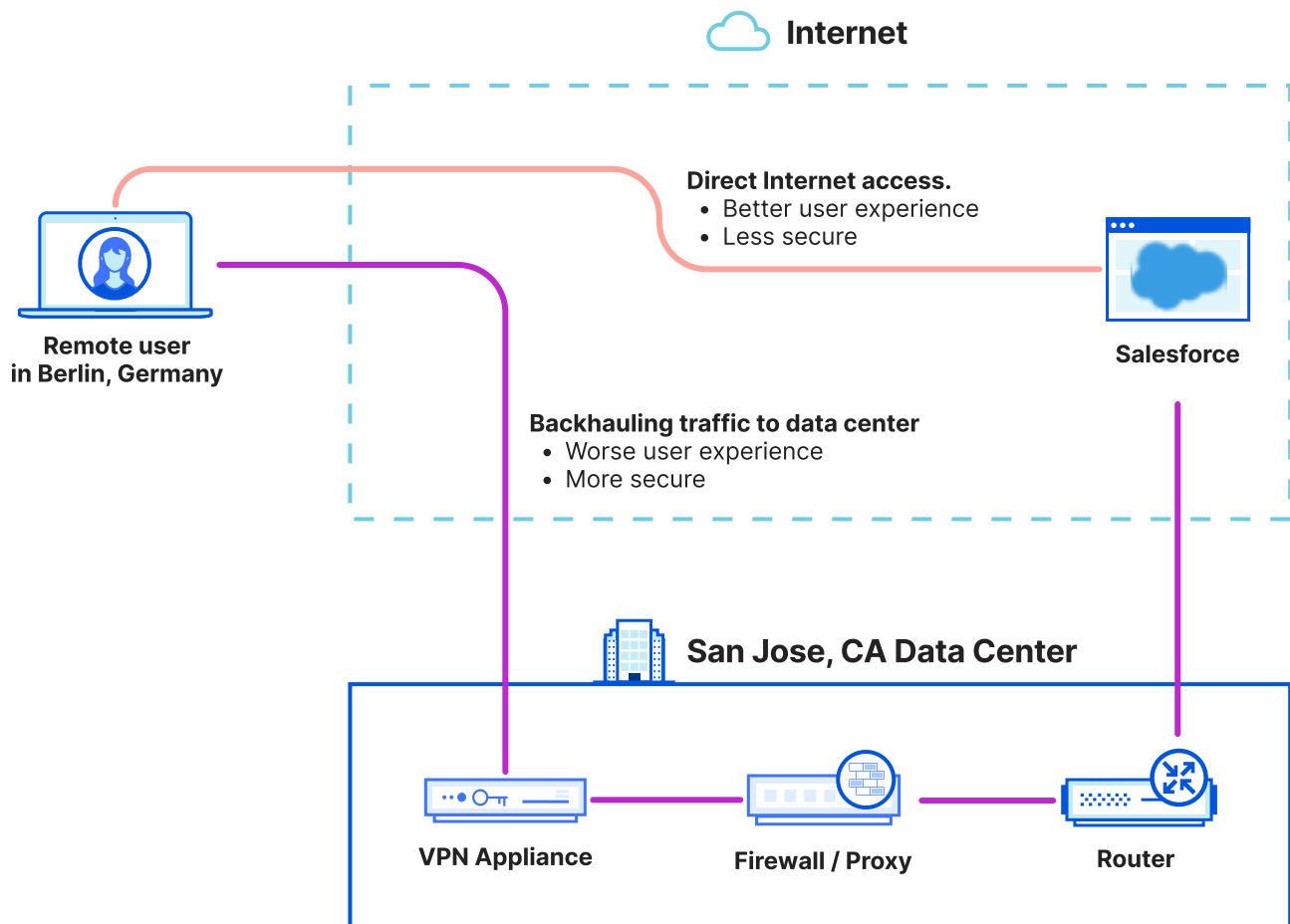


Figure 1: Two different routes to a SaaS application, one secure but low performance, the second fast but less security.

This is where a [SASE \(Secure Access Service Edge\) architecture implementing a Zero Trust framework](#) becomes essential. By centralizing security in a global cloud network, the trade-off between security and performance is eliminated. User traffic no longer needs to be routed through a single remote data center for security. With Cloudflare user traffic is routed into our

services at the nearest data center – out of hundreds – where it will undergo the necessary security controls. These security controls are implemented in a single-pass architecture to avoid adding unnecessary latency and are applied consistently across the entire Cloudflare network.

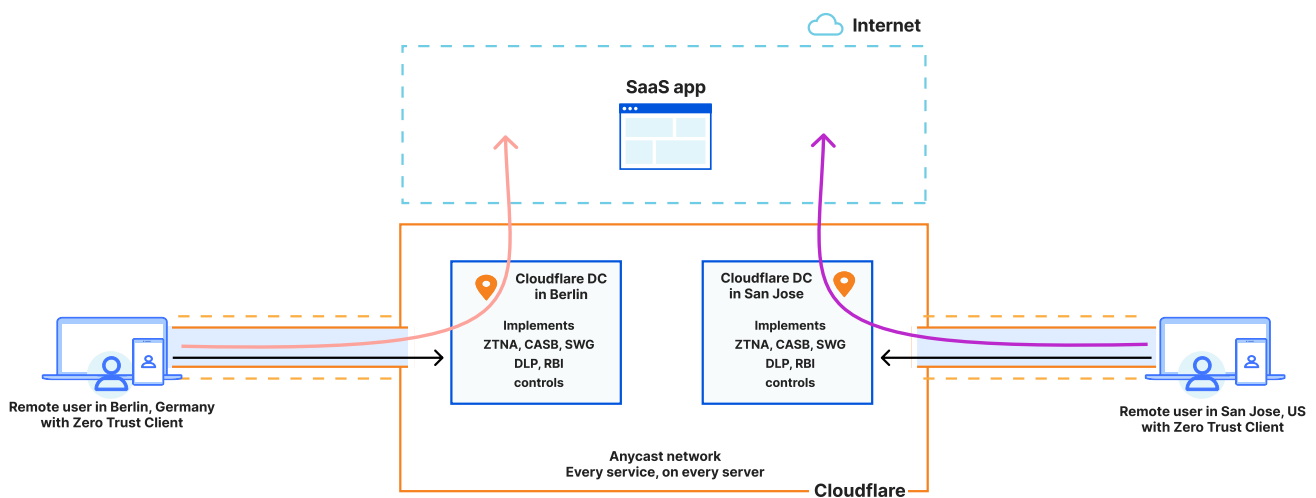


Figure 2: SASE solutions ensure user traffic is secured and filtered close to the user.

This design guide will focus on how Cloudflare's SASE architecture can more effectively and efficiently secure user access to, and the data within SaaS applications. For a broader understanding of how Cloudflare can be used for an organization's zero trust initiatives, please read our [SASE reference architecture](https://developers.cloudflare.com/reference-architecture/design-guides/zero-trust-for-saas/).

Who is this document for and what will you learn?

This guide is designed for IT and security professionals seeking to safely adopt and deploy SaaS applications within their organization while maintaining a positive user experience. It assumes familiarity with concepts such as identity providers (IdPs), user directories, single sign-on (SSO), and data loss prevention (DLP) technologies.

What you will learn:

- How to secure access to managed SaaS applications and protect their data
- Key considerations when using cloud email solutions
- How to get visibility of and regain control over unmanaged SaaS applications

This guide assumes you have an Enterprise contract with Cloudflare that includes:

- Cloudflare Zero Trust licenses for the number of users you plan to onboard
- Cloudflare Cloud Email Security licenses for the number of users whose cloud inbox emails will be filtered

① Free and PayGo capabilities

A lot of the capabilities described in this document [are also available in our free and Pay-as-you-go plans ↗](#).

Recommended resources for a stronger understanding of Cloudflare:

- What is Cloudflare? | [Website ↗](#) (five-minute read) or [video ↗](#) (two minutes)
- Blog: [Zero Trust, SASE, and SSE: Foundational Concepts for Your Next-Generation Network ↗](#) (14-minute read)
- Reference Architecture: [Evolving to a SASE Architecture with Cloudflare](#) (three-hour read)

Securing managed SaaS applications

Managed SaaS applications are those procured and approved by IT, forming part of the official suite of tools employees use to perform their tasks. IT typically manages these applications and are responsible for:

1. **Securing access:** Ensuring only authorized users and devices can access SaaS applications. This includes managing the onboarding and offboarding of users. For instance, if an employee leaves the organization, their access is automatically revoked. Typically this involves integrating the SaaS application with the company identity management solution.
2. **Data protection:** Preventing data leaks from within the SaaS application and proactively mitigating risky behaviors by users that may result in data breaches.
3. **Monitor configuration:** Identifying and promptly correcting misconfigurations within the

SaaS application to ensure they operate securely and efficiently.

4. **Cloud email security:** IT teams should take special care when dealing with cloud email SaaS solutions. Since email is a primary target for attacks, a specialized approach is required to protect users from phishing and other email-based threats.

Note a section later in this document will cover how to gain visibility into, and control over, unmanaged applications. For example where your marketing department decides to sign up and start using a new CRM system without engaging IT or security departments.

Securing access

Using SaaS IP allow lists

One simple method for securing access to SaaS applications, is to only allow access from a specific set of IP addresses. This forces users to have to connect to,

and have their traffic exit from a specific network and therefore ensure whatever access controls are in place on that network are applied to that traffic.

Organizations that already use IP allow lists to secure access to SaaS applications can easily migrate to Cloudflare using [dedicated egress IPs](#). User traffic egresses from Cloudflare to the Internet and onto the SaaS application, sourced from a set of IP addresses unique to the organization. This approach supports various ways in which users access Cloudflare before gaining access to the SaaS application:

- **Hybrid employees:** Connecting to Cloudflare using our Zero Trust client, [WARP](#).
- **Office-based users:** Connecting to a local network which routes Internet bound traffic to Cloudflare through GRE or IPsec [Magic WAN tunnels](#).
- **Contractors and external users:** Accessing SaaS applications through a [remote browser](#) hosted in a Cloudflare data center.

Organizations add the new dedicated egress IPs to the existing SaaS IP allow lists for the Cloudflare sourced traffic to be allowed into the SaaS application. This way, organizations can maintain legacy connectivity methods in parallel with Cloudflare and migrate users gradually. Once all users are migrated to access with Cloudflare, the SaaS IP allow lists can be updated by removing the IPs corresponding to legacy infrastructure.

There are several advantages to using Cloudflare's dedicated egress IPs when compared with using IPs from on-prem infrastructure:

- [Dedicated egress IPs can be geolocated](#) to one or more Cloudflare data centers in a geography of your choosing, instead of being restricted to the geographic locations of your existing Internet breakout data centers.
- Users will always connect to Cloudflare [through the closest Cloudflare Data Center and Cloudflare](#)

[will optimize the path towards the SaaS application.](#)

- Dedicated egress IPs are assigned to user traffic using policies that follow zero trust principles. [Egress policies](#) can be defined that will only assign a dedicated egress IP to a user if they belong to the correct IdP group and/or pass [device posture](#) checks. Otherwise, traffic will be sourced from Cloudflare's public IP range, which may not be part of the SaaS IP allowlist, preventing access to the SaaS application while still allowing Internet usage.
- Dedicated egress IPs imply that traffic needs to flow through Cloudflare before reaching the SaaS application. This makes it easy to add secure web gateway policies to protect data in the SaaS applications once users have authenticated.

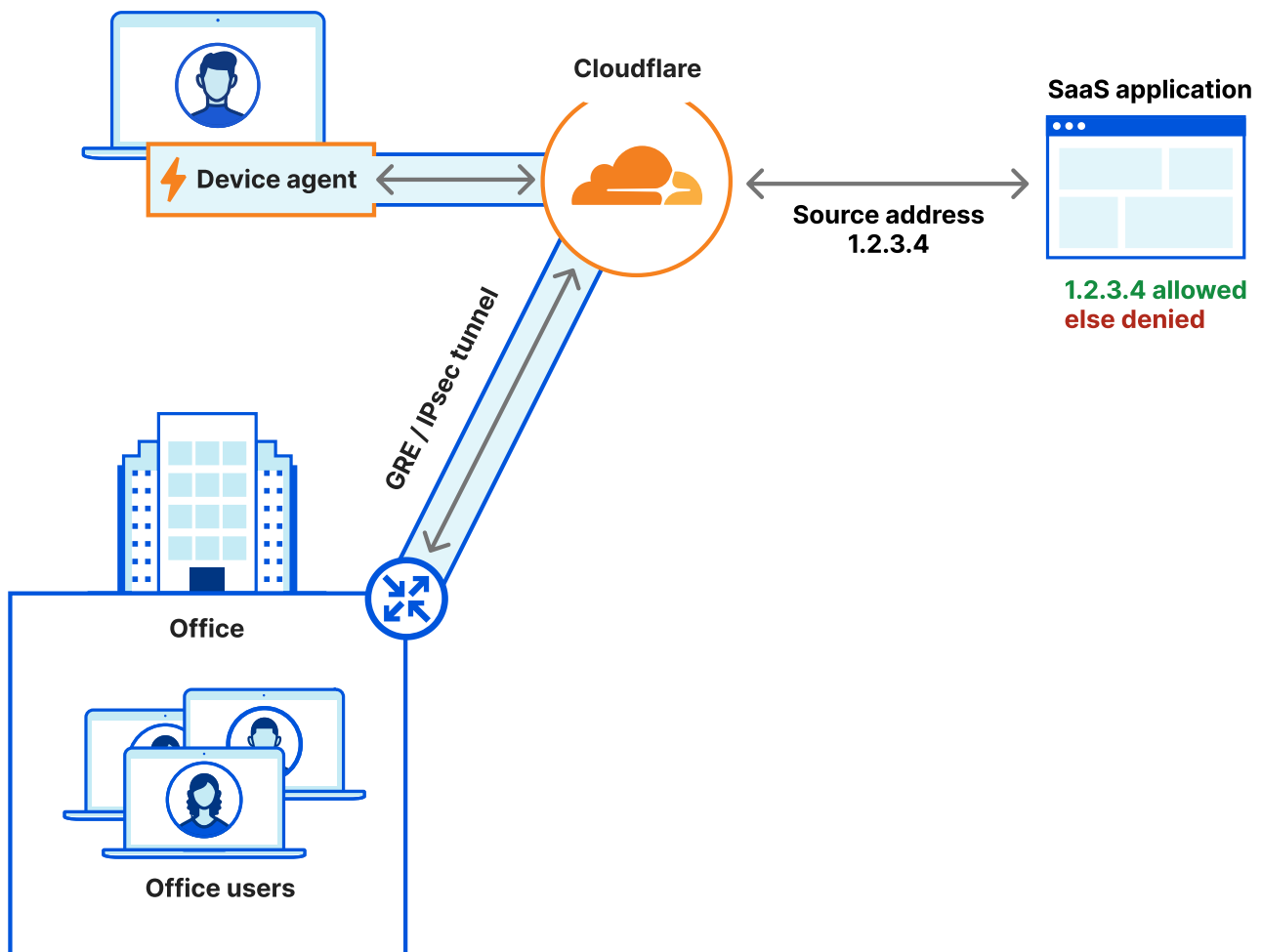


Figure 3: Enforce only traffic that has been secured by Cloudflare is accepted by the SaaS application.

Using Cloudflare as an identity proxy

With Cloudflare, [Zero Trust Network Access \(ZTNA\)](#) [↗] can be applied to managed SaaS applications. In this scenario, Cloudflare acts as the [Single Sign-On \(SSO\)](#) [↗] service for an application, proxying user authentication requests to the organization's existing identity providers (IdPs). This allows for additional restrictions

to be layered on before granting access, such as requiring [multi-factor authentication](#) [↗], implementing [device posture checks](#), or [evaluating the country](#) the request is coming from.

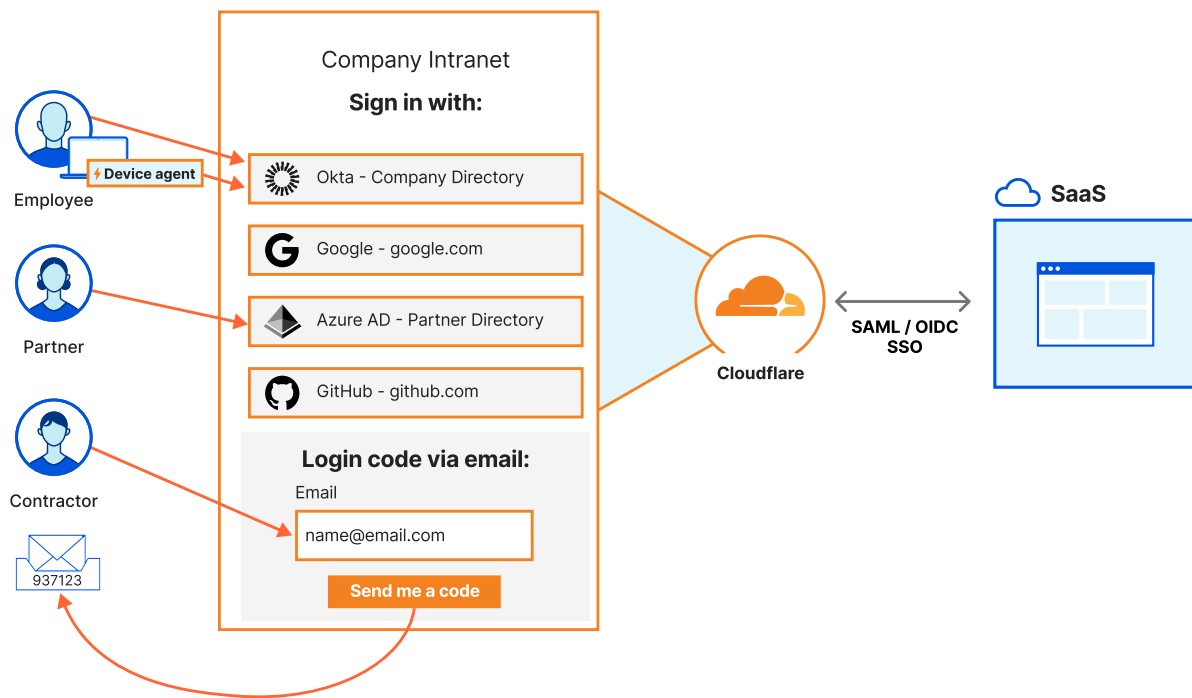


Figure 4: Cloudflare can act as an identity proxy, providing a consistent authentication experience for all SaaS applications.

Most organizations initially use Cloudflare's [ZTNA service](#) for self-hosted applications. Extending it to SaaS applications simplifies IT management in several ways, as both self-hosted and SaaS apps will:

- Use the same access policies
- Leverage the same IdP and device posture integrations
- Consistently audit access requests

IT teams will also benefit from a consistent and automated process for onboarding and offboarding users from applications. Since all access policies leverage authentication from existing IdPs, changes in a user's status will automatically affect the outcome of access requests for both self hosted applications as well as SaaS.

Consider a scenario where a user moves to a different group or team within an organization. As soon as the user group information is updated on the IdP, Cloudflare's ZTNA policies will dynamically enforce these changes, ensuring that the user's access to the SaaS applications is immediately adjusted based on their new role. This also helps in SaaS applications' license optimization. For example, if an employee is transferred from the sales team, which uses Salesforce,

to a team that does not require access to Salesforce, the ZTNA policies will revoke their access to the application. This automated process helps in reclaiming the license that was previously assigned to the user, ensuring that only those who actually need the application have access to it.

Finally, SaaS applications are accessible over the Internet, allowing any device to access them if a user authenticates successfully. However, with Cloudflare's ZTNA service, IT teams can ensure that only managed devices access a SaaS application by enforcing device posture checks, in addition to identity checks. A common use case is [verifying the presence of an IT-deployed device certificate](#) before granting application access.

Deployment guidelines

For SaaS applications that do not support SSO or organizations that are already implementing IP allow lists to secure access to SaaS applications, implementing dedicated egress IPs is the most

straightforward approach to enhance access security to SaaS applications, without impacting the user experience.

Organizations that would like to simplify their onboarding/offboarding of users to applications and standardize ZTNA policies should consider implementing Cloudflare's ZTNA solution for both self-hosted and SaaS applications. In such scenarios, it might still be relevant to consider dedicated egress IPs for a subset of critical SaaS applications. As egress policies operate at the network and transport layers, their enforcement is almost real-time. [For example](#), consider an egress policy for a specific SaaS application that accounts for posture status from an external endpoint management solution. If a device becomes compromised and its posture status becomes non-compliant, the egress policy will no longer match. This results in the user of that device losing access to the SaaS application, as traffic will no longer be sourced from the dedicated egress IP.

Finally, organizations that have already integrated all their SaaS applications with an IdP for SSO can still consider adding IP allow lists with dedicated egress IPs for a subset of applications for the same reason as detailed before.

Data protection for managed SaaS applications

While extending ZTNA principles to managed SaaS applications ensures that only the right users and devices can access these applications, it is crucial to address the risk of authorized users leaking data once they have access.

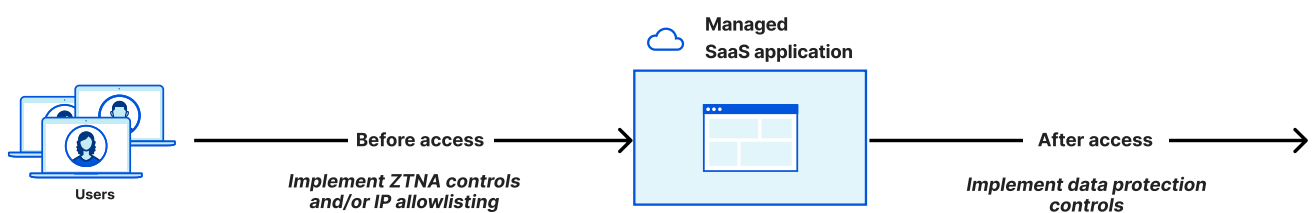


Figure 5: Cloudflare can also protect data that's downloaded or uploaded to managed SaaS applications.

To mitigate these risks, controls should be implemented for both data in transit and data at rest.

Data in transit

As mentioned before, all traffic can be forced through Cloudflare using the device agent, Magic WAN (MWAN) tunnels, or the remote browser. This allows [secure web gateway](#) policies to manage and protect data as it is uploaded or downloaded from SaaS applications. Common use cases include:

- Restricting the ability to download [all](#) or a [subset of files](#) from managed SaaS applications to specific groups of users within the organization.
- Using [Data Loss Prevention \(DLP\)](#) profiles to limit the download of data containing sensitive information from managed SaaS applications.

For more information about securing data in transit, refer to our [reference architecture center](#).

Data at rest

Cloudflare's [Cloud Access Security Broker \(CASB\)](#) integrates with [popular SaaS applications](#) through APIs. Once integrated, Cloudflare continuously scans these applications for security risks. This enables IT teams to detect incidents of authorized users oversharing data, such as sharing a file publicly on the Internet. For Google Workspace, Microsoft 365, Box, and Dropbox, the API CASB can also utilize DLP profiles to detect the sharing of sensitive data. For more information about securing data at rest, refer to our [reference architecture center](#).

In addition to the previous measures, IT teams should also consider introducing [User Entity and Behavior Analytics \(UEBA\)](#) [↗](#) controls. Cloudflare can assign a [risk score](#) to users when detecting activities and behaviors that could introduce risks to the organization. These risk behaviors include scenarios where users trigger an unusually high number of DLP policy matches. By implementing these measures, organizations can significantly reduce the risk of data

leaks from managed SaaS applications, even by authorized users.

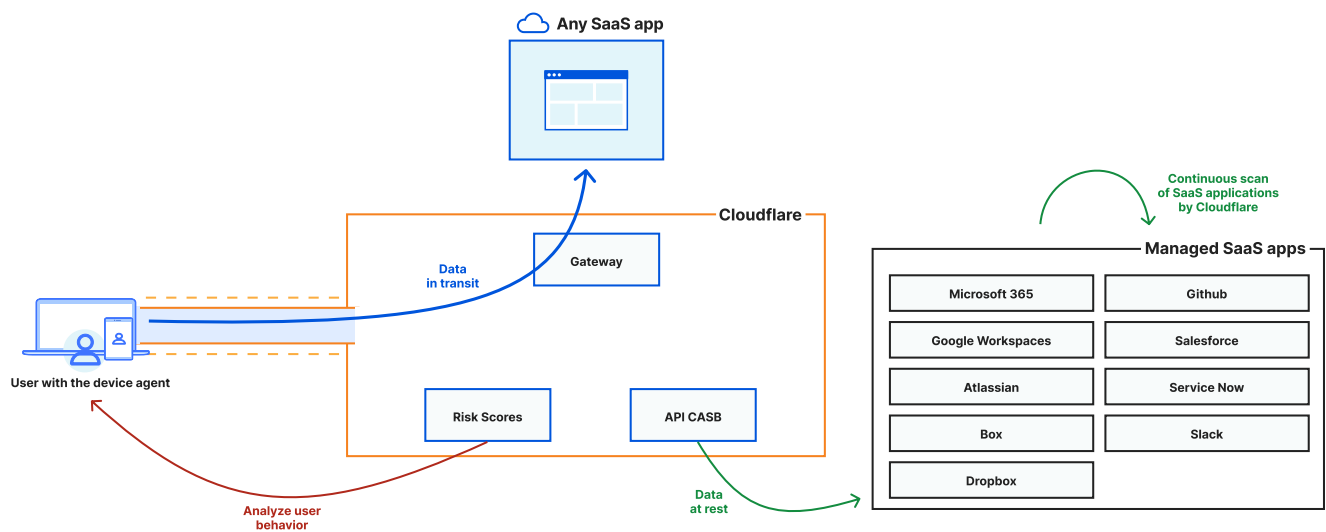


Figure 6: Cloudflare can secure data traveling over its network, as well as using SaaS application APIs to examine data stored at rest.

Monitor configuration

While this design guide has primarily focused on SaaS application users so far, it is important to note that a significant number of SaaS data leaks today are not caused by user behavior but rather by misconfigurations made by IT teams. When these misconfigurations go unchecked, they expose both the

SaaS application and the organization to serious security risks.

You can mitigate these risks using Cloudflare's CASB. The API CASB continuously scans for and identifies misconfigurations, enabling swift remediation. It can detect issues such as exposed credentials, keys that need rotation, users with disabled two-factor authentication (2FA), unauthorized third-party apps with access to the SaaS application, among others.

Cloud email security

Phishing attacks and campaigns to spread malware to take over devices and access company data usually focus on email as the channel for attack. The vast majority of companies today have migrated their email from on-premises servers to cloud hosted services.

While the built-in security of solutions such as Microsoft 365 and Google Workspace are good, they are unable to keep up with the constant evolution of attack methods. Many organizations therefore deploy

advanced email security solutions integrated with existing email platforms.

Securing access

As described already, implementing ZTNA to secure your email platform offers numerous benefits. One key advantage is ensuring that email access is restricted to trusted, managed devices, even when using a cloud-based email service. This typically involves using Cloudflare to verify the presence of a [client certificate](#) and confirm that there are no risks detected by an external endpoint management solution, such as [Crowdstrike](#) or [SentinelOne](#).

Tenant control

Organizations with stringent requirements about email communications for compliance or regulatory reasons, operational control or accountability, or to reduce the potential for data leaks can block access to email tenants other than the organization's own. This can be achieved by using [Cloudflare Gateway SaaS tenant](#)

controls. Cloudflare injects custom HTTP headers into the traffic flow, informing Microsoft 365 and Google Workspace of the specific tenant users are allowed to authenticate into and blocking any access attempts to any other tenant.

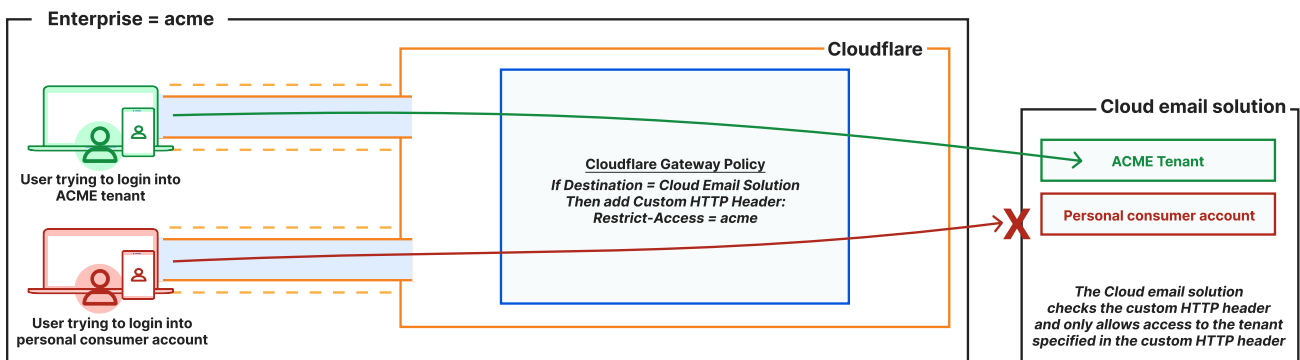


Figure 7: Cloudflare can enforce access to only specific cloud email tenants.

Filtering inbound emails

While SaaS email solutions offer native security capabilities, their popularity makes them high-value targets for attackers who seek to exploit vulnerabilities and limitations in their inbound filtering capabilities. To mitigate this risk, IT teams should consider supplementing the native capabilities of cloud email

solutions with specialized solutions for inbound email filtering.

[Cloudflare's Email Security ↗](#) scans for malicious content or attachments in emails and proactively monitors the Internet for attacker infrastructure and attack delivery mechanisms. It identifies programmatically-created and impersonation domains used to host malicious content as part of planned attacks. This data also helps protect against business and vendor email compromises ([BEC ↗](#)/[VEC ↗](#)), which are notoriously difficult to detect due to their lack of payloads and resemblance to legitimate email traffic and a gap for legacy email security platforms.

Integrating Cloudflare into the existing email infrastructure is both flexible and straightforward, with deployment options available in [inline](#) and [API](#) modes.

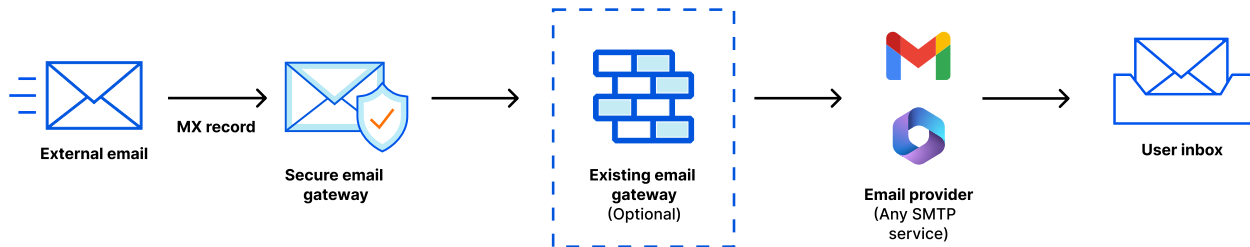
In an inline deployment, Cloudflare's Email Security will evaluate email messages before they reach a user's inboxes (by pointing the email domain MX record to Cloudflare). This allows Cloudflare to [quarantine](#)

[messages](#) so they never reach the user's inbox or [tag messages with email headers](#) to inform the email provider how emails should be handled (for example, [by redirecting bulk emails directly to the spam folder](#)). Cloudflare can also [modify the subject and body of email messages](#) to inform a user to be more cautious about a suspicious email and [rewrite links within emails and even isolate those links behind a remote browser](#).

In an API deployment, Cloudflare's Email Security will see the email messages only after they have reached the users' inboxes by setting up Journaling/BCC rules in the email provider or through API scan. Then, through integrations with the email provider, Cloudflare can [retract phishing emails](#) from users' inboxes. Unlike the inline mode, this deployment method does not support quarantining emails or modifying the email messages. However, it is an easy way to add protection in complex email infrastructures with no changes to the existing mail flow operations.

These modes can be used concurrently to enhance email security. The inline mode ensures that Cloudflare's Email Security scans and filters emails before they reach users' inboxes. For emails that initially pass through without being flagged as threats, Cloudflare [periodically re-evaluates them](#). If these emails are later identified as part of a phishing campaign, they are automatically retracted with the API. This proactive approach protects organizations against deferred phishing attacks, where attackers send emails with seemingly benign links that are weaponized after delivery to bypass initial detection.

Inline mode



API mode

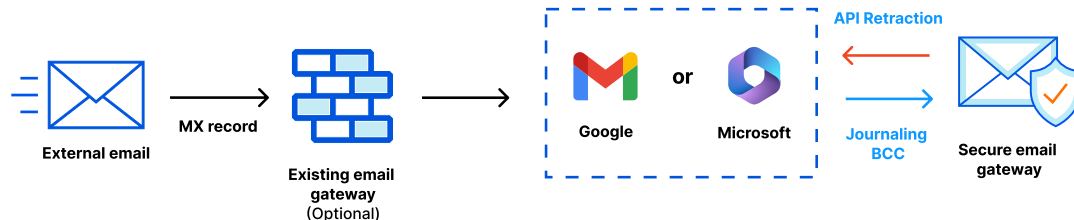


Figure 8: Cloudflare can protect email services either inline or by API.

Ensuring availability

Cloudflare also helps ensure the availability of cloud email services. It auto-scales TCP connections and SMTP traffic to handle message spikes, protecting the organization from email DoS attacks. The service automatically pools and queues messages for extended periods and throttles delivery post-spike according to the downstream email service's capacity. This pooling and queuing capability is beneficial during cloud email service outages.

Filtering outbound emails with outbound data loss prevention

Organizations using Microsoft 365 can enhance protection against sensitive information leaks through email by integrating a Cloudflare add-in into their environment. This integration enables IT administrators to establish [outbound Data Loss Prevention \(DLP\) policies](#) that leverage the same DLP profiles used with the Secure Web Gateway (SWG) and API Cloud Access Security Broker (CASB).

Moreover, organizations that utilize [Microsoft Purview Sensitivity Labels](#) for classifying and safeguarding sensitive documents can incorporate these labels into Cloudflare's DLP profiles. This capability allows the creation of targeted policies, such as blocking emails containing Microsoft Office documents marked as 'Highly Confidential' in Microsoft Outlook from being sent to external recipients. These DLP profiles can also be applied across SWG and API CASB.

Regain control over unmanaged SaaS applications

Unmanaged SaaS applications are those used by employees without IT's approval or knowledge, commonly referred to as [shadow IT](#) . This growing challenge is driven by the proliferation of free or low-cost SaaS applications. While these apps can boost employee satisfaction and productivity, they also pose significant risks, such as:

- **Data breaches:** Employees can upload sensitive data to these applications without any security controls. And without Single Sign-On (SSO) or strong password protocols, the risk of data loss or theft is significantly higher.
- **Compliance violations:** In regulated industries, the use of unauthorized SaaS tools can lead to non-compliance with legal and industry

standards, potentially resulting in fines, legal action, and reputational damage.

- **Increased costs:** IT typically can often secure favorable pricing by managing SaaS subscription across the business. However, when employees independently purchase subscriptions with personal credit cards, it can lead to unchecked shadow IT spending and higher overall costs for the organization.

To mitigate these risks, the first step is to discover which SaaS applications employees are using. When all traffic from employee devices is routed through Cloudflare, [reports are generated](#) showing the usage of common SaaS applications.

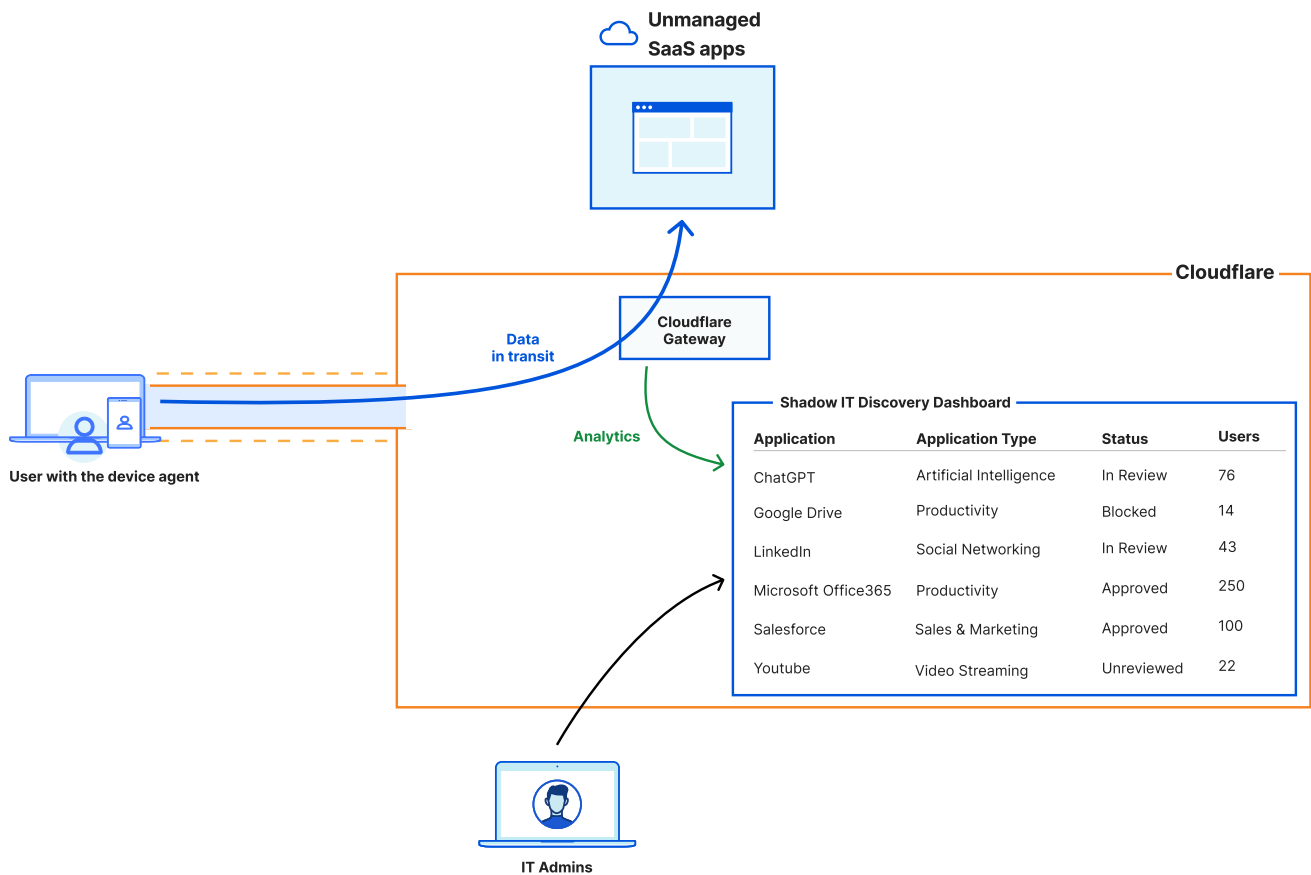


Figure 9: When all user traffic bound for the Internet goes via Cloudflare, it allows IT to monitor for unapproved SaaS applications.

With this information, IT teams can analyze and decide how to handle each unmanaged SaaS application:

- **Allow the application:** If the application presents no risk to the organization, it is deemed acceptable for employee use, and no further action is required.

- **Allow the application with data protection controls:** If the application is acceptable but poses a data leak risk, appropriate data protection measures should be implemented.
- **Adopt the application as a managed SaaS application:** If the application is beneficial for the organization, it should be brought under IT management.
- **Block the application:** If the application is deemed unacceptable, it should be blocked using Cloudflare Gateway DNS and/or HTTP policies.

Data protection for unmanaged SaaS applications

Data protection for unmanaged SaaS applications is similar to that for managed SaaS applications, but the focus shifts from mitigating the downloading of data to preventing the uploading of sensitive information. Policies can be configured using Cloudflare Gateway to address these risks. Common use cases include:

- Restricting the ability to [upload certain file types](#) to SaaS applications, limiting this capability to specific groups of users within the organization.
- Using Data Loss Prevention (DLP) profiles to block the upload of data containing sensitive information.

In addition to these measures, [remote browser isolation](#) can be considered for unmanaged SaaS applications. This approach allows users to access certain unmanaged SaaS applications while [restricting their actions within those applications](#) to prevent misuse.

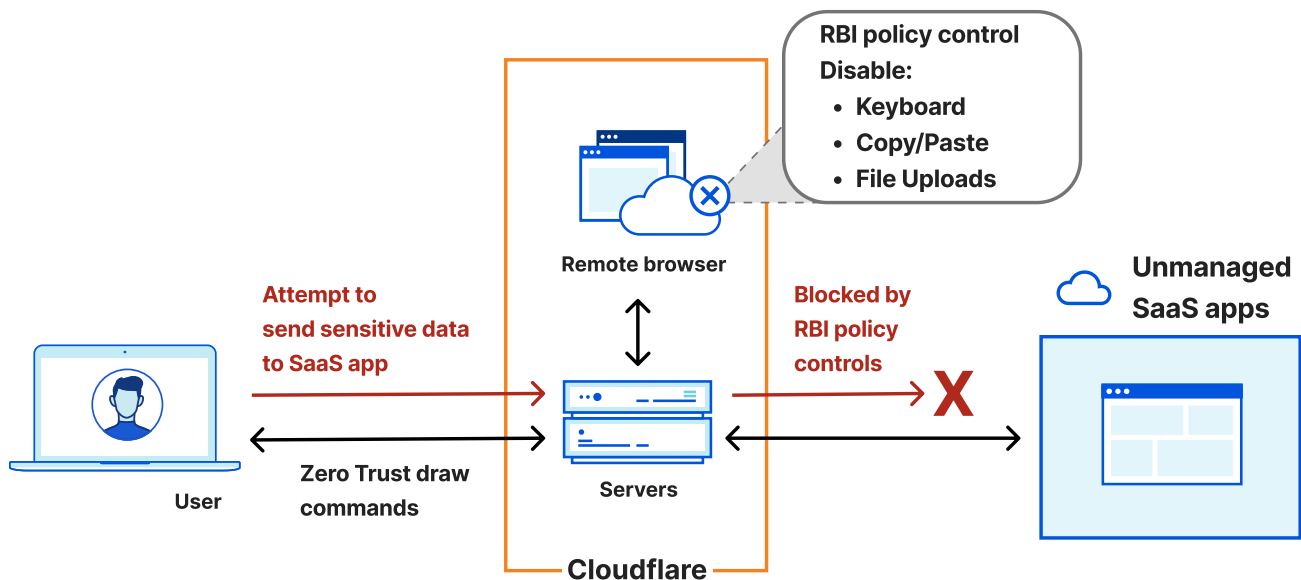


Figure 10: DLP policies can be combined with browser isolation, to protect company data.

Adopting a new SaaS application

Many SaaS applications offer a free version as part of their business model to encourage users to integrate them into their work. This helps demonstrate the application's usefulness and facilitates its adoption at the corporate level ([Cloudflare follows this model as well ↗](#)). When a previously unmanaged SaaS application is officially adopted by the organization, IT teams take over its management to ensure proper support and adherence to best practices. This involves

aligning the new SaaS application with all the aspects discussed in the Securing Managed SaaS Applications section.

After fully adopting the new SaaS application, access to the consumer version may be restricted. If the corporate SaaS version has a unique domain, access to other tenant domains or the consumer domain can be blocked using Cloudflare DNS and/or HTTP policies. Some SaaS solutions offer [native tenant control](#) through HTTP headers, which can be enforced by injecting these headers for data in transit using Cloudflare Gateway HTTP policies.

Summary

This design guide described how organizations can enhance their SaaS application security by implementing a Zero Trust framework within a SASE architecture. With Cloudflare, organizations gain access to a comprehensive solution that addresses the challenges posed by both managed and unmanaged

SaaS applications. By using techniques like ZTNA, dedicated egress IPs, CASB, and robust email security measures, organizations can ensure secure access, protect sensitive data, and gain control over shadow IT, all while maintaining a positive user experience. These techniques and when to apply them are summarized in the diagram below:

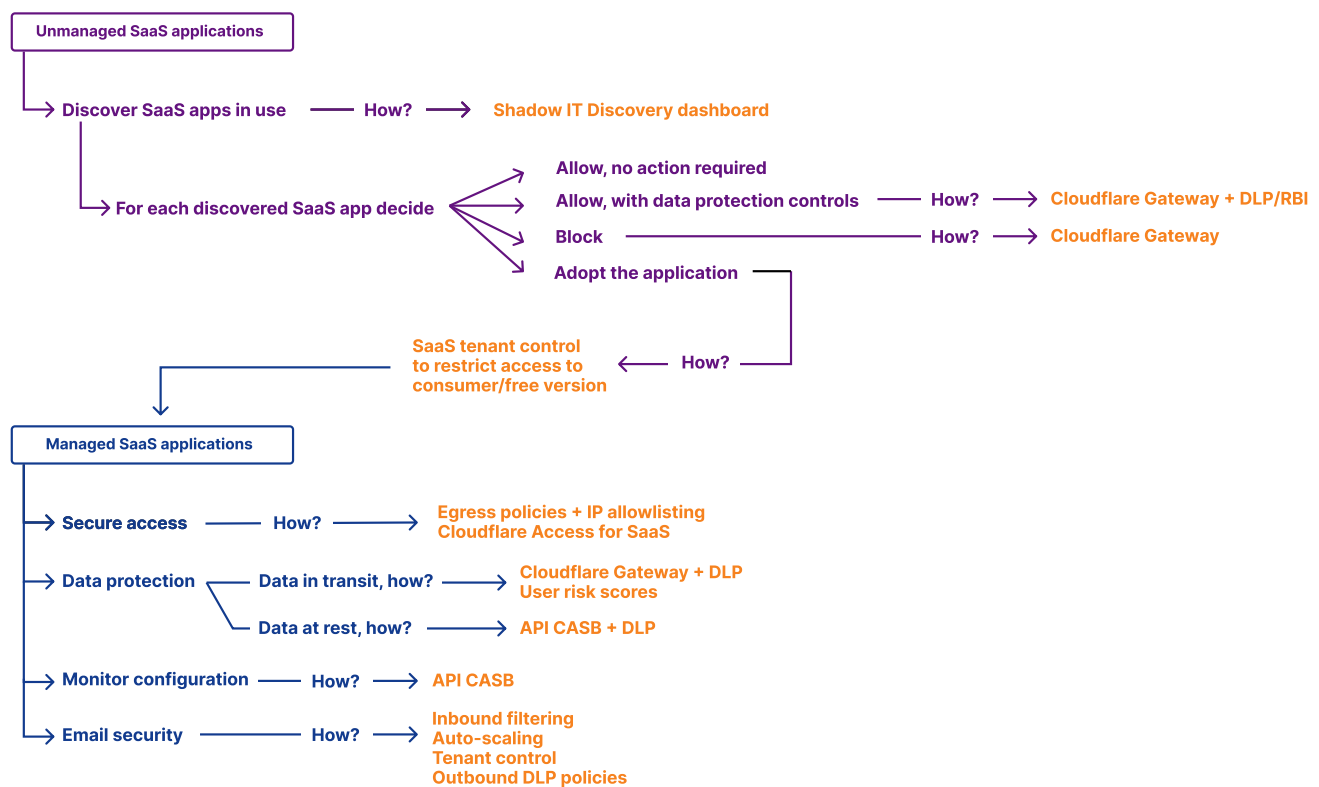


Figure 11: Techniques for enforcing a zero trust approach in SaaS applications.

Related resources

- [SASE reference architecture](#)
- [Using Cloudflare SASE with Microsoft](#)

Was this helpful?



Previous

Next

← Leveraging Cloudflare for your SaaS applications →
Designing ZTNA access policies

Last updated: Oct 9, 2025

Resources

API

New to Cloudflare?

Directory

Sponsorships

Open Source

Support

Help Center

System Status

Compliance

GDPR

Company

Tools

[cloudflare.com](#)[Cloudflare Radar](#)[Our team](#)[Speed Test](#)[Careers](#)[Is BGP Safe Yet?](#)[RPKI Toolkit](#)[Certificate Transparency](#)

Community

[!\[\]\(d8ab143e904bfa3467271eec5af75a9b_img.jpg\) X](#)[!\[\]\(4688aadfd656ded00cd6bdfae55089a9_img.jpg\) Discord](#)[!\[\]\(e9474ce1d70442456f8fe9c393ea149c_img.jpg\) YouTube](#)[!\[\]\(e3f255517d37bb309a3a931ec4849e6a_img.jpg\) GitHub](#)

© 2025 Cloudflare, Inc. • [Privacy Policy](#) • [Terms of Use](#)

• [Report Security Issues](#) • [Trademark](#) •  [Cookie Preferences](#)